

Information Systems Security

Exam-Style Questions and Model Answers

Lectures 1 to 5 | 5 questions per lecture | 4 to 6 marks each
Lecture 5 covers topics up to Mesh Topology only

Lecture	Topic
1	Introduction to Information Systems Security
2	Information Systems Security Vulnerabilities
3	Threat Modelling and Scoping an Information System
4	Identification, Authentication and Access Control
5	Network Information System (up to Mesh Topology)

Lecture 1: Introduction to Information Systems Security

Q1. Define an Information System and explain any four of its components. (5 marks)

Answer

An Information System (IS) is a coordinated collection of components that collect, process, store and distribute information to support decision-making, coordination, control and business operations. (1)

Any four components (1 mark each):

- **People:** The most important component, e.g. employees, managers, administrators. Humans are often the weakest link because of social engineering, poor password practices and accidental mistakes.
- **Hardware:** Servers, PCs, routers and storage devices. Hardware failures can cause service interruptions and data loss.
- **Software:** OS, DBMS, ERP and email software. Software vulnerabilities are a major source of cyberattacks.
- **Data:** The most valuable asset, e.g. student and medical records. Loss or corruption can have operational, legal and reputational consequences.
- **Procedures:** These define how systems should be used, e.g. backup procedures and password policies. They reduce human error and improve consistency.
- **Networks:** LAN, WAN and the Internet. Improperly secured networks become entry points for attackers.

Q2. Explain the CIA Triad. Give one example of a violation for each principle. (6 marks)

Answer

- **Confidentiality** ensures information is accessible only to authorised individuals. (1) Example: a student gains access to an examination paper before the exam. (1)
- **Integrity** ensures information is accurate, complete and unaltered. (1) Example: an attacker changes a student's mark from 62 to 92. (1)
- **Availability** ensures information is accessible when required. (1) Example: a DDoS attack stops students from accessing the university portal during online registration. (1)

Q3. Define the terms *asset*, *threat*, *vulnerability* and *risk*. Give one example of each. (4 marks)

Answer

- **Asset:** Anything of value that requires protection. Example: databases. (1)
- **Threat:** Any event that has the potential to cause harm. Example: hackers, floods. (1)
- **Vulnerability:** A weakness that can be exploited. Example: weak passwords, unpatched software. (1)
- **Risk:** The likelihood that a threat will exploit a vulnerability and cause harm to an asset. $\text{Risk} = \text{Threat} \times \text{Vulnerability} \times \text{Impact}$. Example: an exposed web server facing frequent attacks and hosting critical student records is high risk. (1)

Q4. State the three classes of security controls and give two examples of each. (6 marks)

Answer

- **Preventive controls (1):** Firewalls, encryption, MFA, security awareness training (any two). (1)
- **Detective controls (1):** Intrusion Detection Systems (IDS), security logs, SIEM solutions, CCTV (any two). (1)
- **Corrective controls (1):** Backups, Disaster Recovery Plans, patch management, incident response (any two). (1)

Q5. With reference to the WannaCry ransomware attack (2017), describe the attack, state its impact and give lessons learned. (6 marks)

Answer

Attack (2): WannaCry spread globally within hours by exploiting a vulnerability in Microsoft Windows systems. It encrypted users' files and demanded payment in cryptocurrency for decryption.

Impact (any two, 2):

- Over 200,000 computers were affected.
- More than 150 countries were impacted.
- Hospitals, universities, businesses and government agencies had major disruptions.
- There were significant financial losses and operational downtime.

Lessons learned (any two, 2):

- Apply security patches promptly.
- Maintain offline and tested backups.
- Segment networks to limit lateral movement.
- Train users to recognise suspicious activity.
- Develop and regularly test incident response and disaster recovery plans.

Lecture 2: Information Systems Security Vulnerabilities

Q1. Define a security vulnerability and state four reasons why vulnerabilities exist. (4 marks)

Answer

A security vulnerability is a weakness or flaw in the design, implementation, configuration or operation of an information system. It can be exploited by a threat actor to compromise the confidentiality, integrity or availability of information. (2)

Any four reasons (½ mark each):

- Programming mistakes
- Poor software design
- Human error
- Misconfiguration
- Lack of updates
- Weak security policies
- Complex systems
- Legacy software
- Third-party software dependencies

Q2. Using an example of a cybercriminal attacking a student database, explain the terms *threat*, *exploit*, *vulnerability*, *asset* and *impact*. (5 marks)

Answer

- **Threat:** The source of danger, e.g. a cybercriminal. (1)
- **Exploit:** The method used to take advantage of the weakness, e.g. a password guessing attack. (1)
- **Vulnerability:** The weakness, e.g. a weak administrator password. (1)
- **Asset:** The thing of value being attacked, e.g. the Student Information Database. (1)
- **Impact:** The damage caused, e.g. student records stolen. (1)

Q3. Explain *buffer overflow* and *SQL injection*. State how SQL injection can be prevented. (6 marks)

Answer

Buffer overflow (3):

- It occurs when a program writes more data into memory than was allocated. (1)
- Example: an application expects 20 characters but the user enters 500. Without validation, memory is overwritten. (1)
- Consequences: system crash, privilege escalation, remote code execution (any two). (1)

SQL injection (3):

- It occurs when user input is interpreted as SQL commands. For example, an attacker enters ' OR '1'='1 and this causes authentication bypass. (1)
- Prevention (any two, 2): parameterised queries, prepared statements, input validation, least-privilege database accounts.

Q4. Describe three common network vulnerabilities. Explain how unencrypted communication and poor network segmentation put a system at risk. (5 marks)

Answer

- Any three common network vulnerabilities: open ports, weak Wi-Fi encryption, default router passwords (e.g. admin/admin), insecure protocols (Telnet, FTP), poor network segmentation, unpatched network devices. (3)

- **Unencrypted communication:** Using HTTP instead of HTTPS exposes usernames, passwords and session cookies. Attackers on the same network can intercept them. **(1)**
- **Poor network segmentation:** All devices are on a single flat network. If one device is compromised, malware can spread rapidly to other systems. **(1)**

Q5. Describe three common mobile device vulnerabilities and three security controls that can be used to protect mobile devices. (6 marks)

Answer

Vulnerabilities (3):

- **Weak authentication:** simple PINs, no biometrics, no MFA.
- **Insecure applications:** poor encryption, excessive permissions, data leakage.
- **Lost or stolen devices:** a lost phone may expose emails, documents and credentials.

Controls (any three, 3):

- **Mobile Device Management (MDM):** software that lets organisations secure, monitor, manage and push policies to mobile devices from a central platform.
- **Device encryption:** scrambles data into an unreadable format so it is protected if the device is lost or stolen.
- **Remote wipe:** a command sent over the internet to delete all data and reset a lost or stolen device.
- **Application control:** blocks unauthorised software, scripts and code from running.
- **Biometric authentication:** verifies identity using unique physical or behavioural traits instead of a password or PIN.

Lecture 3: Threat Modelling and Scoping an Information System

Q1. Define threat modelling and state four benefits of threat modelling. (4 marks)

Answer

Threat modelling is a structured process used to understand a system from a security perspective, identify what could go wrong, and determine appropriate security controls. (2)

Any four benefits (½ mark each):

- Identifies security weaknesses early.
- Reduces the cost of fixing design flaws.
- Improves security requirements.
- Helps developers understand attack scenarios.
- Supports risk-based security decisions.
- Helps identify appropriate security controls.
- Supports security testing.
- Improves communication between developers, security teams and management.
- Helps protect business-critical assets.

Q2. Explain how threat modelling is incorporated into the Software Development Life Cycle (SDLC). State the threat modelling activity at each stage. (6 marks)

Answer

Threat modelling should not be done only after development. It should be done throughout the SDLC, because the earlier a design weakness is found, the easier and cheaper it is to fix. (1)

Any five stages (1 mark each):

- **Requirements:** identify security requirements and important assets.
- **Architecture:** identify components, data flows and trust boundaries.
- **Design:** identify potential threats and attack paths.
- **Development:** review security assumptions and implementation.
- **Testing:** develop security test cases.
- **Deployment:** review infrastructure and external dependencies.
- **Operations:** update the threat model when the system changes.

Q3. State and briefly explain the four steps of the OWASP threat modelling process. (4 marks)

Answer

- **Scope your work:** understand what is being protected and how the system works. (1)
- **Determine threats:** identify what could go wrong. (1)
- **Determine countermeasures and mitigation:** decide how the identified threats should be addressed. (1)
- **Assess your work:** evaluate whether the threat modelling exercise was sufficiently complete. (1)

Q4. Explain the STRIDE model. For each threat, give one mitigation technique. (6 marks)

Answer

STRIDE is a mnemonic that helps identify threats by making us think like an attacker.

Threat	Meaning	Mitigation
Spoofing	Pretending to be another user	Appropriate authentication
Tampering	Modifying data	Hashes / digital signatures / MACs

Threat	Meaning	Mitigation
Repudiation	Denying an action	Audit trails / timestamps / digital signatures
Information Disclosure	Exposing confidential data	Encryption / authorization
Denial of Service	Making a service unavailable	Throttling / filtering / quality of service
Elevation of Privilege	Obtaining unauthorized privileges	Run with least privilege

(1 mark per threat with its meaning and one mitigation)

Q5. Define *entry point*, *exit point* and *trust level*. Give two examples of entry points. (5 marks)

Answer

- **Entry point:** An interface through which an attacker or user can interact with the application or supply it with data. **(1)**
- **Exit point:** The place where data or information leaves a system or component. **(1)** Example pairs: login form to web response; file upload to file download. **(1)**
- **Trust level:** The degree of access or privilege granted to an entity. Trust generally increases as privileges increase. **(1)**
- Examples of entry points (any two): login page, registration form, search box, REST API, file upload, web service, mobile application, network port, email interface, administrative console. **(1)**

Lecture 4: Identification, Authentication and Access Control

Q1. Differentiate between identification, authentication, authorization and accountability. (4 marks)

Answer

- **Identification:** The process by which a user claims an identity, e.g. entering a username. The system has not yet verified the claim. **(1)**
- **Authentication:** Verifying that the claimant is actually associated with the identity being claimed, e.g. password + MFA. **(1)**
- **Authorization:** Deciding what the authenticated user is allowed to access, e.g. a student can view their own results. **(1)**
- **Accountability:** Being able to associate actions with the responsible user, supported by logging, monitoring and audit trails. **(1)**

Q2. List and explain the five authentication factors, giving one example of each. (5 marks)

Answer

- **Something you know:** password, PIN, passphrase. **(1)**
- **Something you have:** smartphone, OTP generator, digital certificate. **(1)**
- **Something you are:** biometric authentication, e.g. fingerprint, face. **(1)**
- **Somewhere you are:** IP address, geofencing. **(1)**
- **Something you do:** typing patterns, touchscreen behaviour. **(1)**

Q3. Explain how passwords should be stored securely. In your answer, discuss hashing, salting and the choice of hashing algorithm. (6 marks)

Answer

- **Hashing (2):** Passwords should be hashed, not reversibly encrypted. Hashing is a one-way transformation, so the original password cannot be recovered from the hash. Encryption is reversible when the key is available.
- **Salt (2):** A salt is a unique random value added to the password before hashing. Without salts, two users with the same password would produce the same stored hash. Salting makes precomputed password attacks much more difficult.
- **Algorithm (2):** Fast hashes like SHA-256 are not suitable, because attackers can make huge numbers of guesses. Password hashing should be deliberately slow, computationally expensive and preferably memory-intensive. OWASP recommends algorithms such as Argon2id.

Q4. Define Multi-Factor Authentication (MFA). Give two examples of MFA and explain why "Password + PIN" is not MFA. (5 marks)

Answer

- MFA requires authentication using more than one independent factor category. **(2)**
- Examples (any two): Password (something you know) + authentication app (something you have); Password + fingerprint (something you are). **(2)**
- Password + PIN is not MFA because both are "something you know", so they belong to the same factor category. **(1)**

Q5. Explain the four access control models: DAC, MAC, RBAC and ABAC. State two advantages of RBAC. (6 marks)

Answer

- **DAC (Discretionary):** The owner of a resource controls access. It is flexible, but users may unintentionally give excessive access. **(1)**
- **MAC (Mandatory):** Access is decided by centrally defined security policies and classifications (e.g. Top Secret, Secret, Confidential, Public). **(1)**
- **RBAC (Role-Based):** Permissions are assigned to roles, and users are assigned to roles, e.g. student, lecturer, administrator. **(1)**
- **ABAC (Attribute-Based):** Decisions are based on attributes of the user, resource and environment, e.g. role, department, location, time. For example: IF User.Role = Lecturer AND Resource.Course = User.AssignedCourse AND Time = WorkingHours THEN Allow, else Deny. **(1)**
- **Advantages of RBAC (any two, 2):** easier administration, supports least privilege, easier onboarding/transfer/termination of employees, supports separation of duties.

Lecture 5: Network Information System (up to Mesh Topology)

Q1. Define the terms *network* and *computer network*. What is the primary objective of a computer network? (4 marks)

Answer

- A **network** is a set of devices (nodes, terminals or stations) interconnected by communication links. (1)
- A **computer network** is a collection of computers and terminal devices connected together by a communication system to share resources and information. (1)
- The primary objective is **resource sharing**. (1) This includes device sharing, file sharing, program sharing and program segmentation (any two). (1)

Q2. Explain any six ways in which a computer network can help a business. (6 marks)

Answer

Any six (1 mark each):

- **File sharing:** data files stored on the server are easily accessible to all staff.
- **Print sharing:** resources such as hard disks and printers are shared by multiple users, which reduces the cost of installing and maintaining multiple resources.
- **E-mail:** collaboration tools such as group email let staff communicate quickly and effectively.
- **Remote access:** users can access data from the organisation's network via the Internet in a cost-effective manner.
- **Shared databases:** multiple users access databases at the same time while the integrity of the database is ensured.
- **Fault tolerance:** backups protect against accidental data loss, and a server with UPS protects against power failure.
- **Internet access and security:** access to the Internet and the World Wide Web, with data security maintained through a firewall.

Q3. Explain the area-coverage based classification of computer networks. (5 marks)

Answer

- **PAN (Personal Area Network):** used for data transmission among devices such as computers, telephones and personal digital assistants. (1)
- **LAN (Local Area Network):** a group of computers and network devices connected together, usually within the same building or campus or over a limited distance. It provides high-speed data transfer and is relatively inexpensive. (1½)
- **MAN (Metropolitan Area Network):** a larger network that usually spans the same city or town. Cable network is an example. (1)
- **WAN (Wide Area Network):** not restricted to a geographical location, although it may be confined within a state or country. It is high speed and relatively expensive. The Internet is an example of a world-wide public WAN. (1½)

Q4. Compare the Client-Server and Peer-to-Peer network architectures. (6 marks)

Answer

Client-Server (1): Consists of servers (powerful computers running network operating systems) and clients (user workstations) that access data or run applications located on the servers.

- Advantages (any two, 1): it can be scaled up to many services and users; all data is stored on servers, which have greater security controls and can control access; it is more secure than peer-to-peer.
- Disadvantages (any one, ½): if the server crashes, all connected computers become unavailable; simultaneous access takes the server more time to process.

Peer-to-Peer (1): There are no dedicated servers. All computers are equal and are called peers. Peer-to-peer networks are also known as workgroups.

- Advantages (any one, ½): simple design and maintenance; no single computer controls the whole network; if one computer fails, the others continue to work; cost effective.
- Disadvantages (any two, 1): problems accessing files if computers are not connected properly; does not support too many computers; data security is very poor.

(Remaining 1 mark for a clear comparison covering both architectures.)

Q5. Describe the star topology and the mesh topology. State one advantage and one disadvantage of each. (6 marks)

Answer

Star topology (3):

- Communication channels emanate from a centralised control. The processing nodes interconnect directly with a central system. It is suitable for organisations needing a centralised database or processing facility, e.g. banking. **(1)**
- Advantage (any one): easy to add or remove nodes; a node failure does not bring down the whole network; easier to diagnose problems through the central hub. **(1)**
- Disadvantage (any one): if the central hub fails, the whole network stops; it costs more to cable because more cable is needed. **(1)**

Mesh topology (3):

- It may be fully connected or partially connected. In a fully connected mesh, each node has a dedicated point-to-point link to every other node, so no routing function is needed. Reliability is very high because alternate paths exist if a link fails. **(1)**
- Advantage (any one): the greatest amount of redundancy, because traffic can be redirected if a node fails; network problems are easier to diagnose. **(1)**
- Disadvantage: the cost of installation and maintenance is high, because more cable is required than in any other configuration. **(1)**